

**민감정보 파일 반출 탐지를 위한 AI 기반 Host DLP
시스템 설계 및 구현 — 중간보고서**



팀명: Sentry

202155550 / 박동화 / hvva1816@gmail.com

202121161 / 김진우 / a01047463862@gmail.com

202155579 / 이상호 / ttt1253@naver.com

지도교수: 최윤희

제출일: 2026년 7월 9일

목차

1	서론	2
1.1	모듈별 진행 현황 요약	2
2	시스템 아키텍처 및 AI 연동 파이프라인	2
2.1	전체 시스템 구조	2
2.2	AI 판별 엔진 연동 파이프라인	3
3	Host Agent 개발 현황	3
3.1	개발 범위 및 진행 상태	4
3.2	세부 모듈 구조	4
3.3	구현 완료 항목	4
3.4	테스트 현황	4
3.5	주요 기술 결정 및 근거	5
3.6	미완료 항목 및 향후 과제	5
4	AI 모델 및 분석 서버 개발 현황	5
4.1	초기 데이터셋 구성 및 학습	5
4.2	문제 발견: 도메인 편향(Out-of-Distribution 성능 저하)	6
4.3	원인 분석	6
4.4	데이터셋 재설계 방향	6
4.5	파일럿 검증 결과 및 향후 계획	6
4.6	분석 서버 가동 환경	7
5	테스트 결과 및 통합 테스트 계획	7
6	웹 대시보드 개발 현황	7
6.1	개발 범위 및 구현 상태	8
6.2	백엔드 및 REST API 구현	8
6.3	프론트엔드 화면 구현	8
6.4	샘플 데이터 및 검증 현황	10
6.5	미완료 항목 및 향후 과제	10
7	구성원별 진척도	11
8	향후 추진 계획	11

1. 서론

본 보고서는 착수보고서에서 제안한 「2단계 하이브리드 탐지(Rule 기반 1차 필터링 + KoELECTRA 기반 2차 문맥 분석)」 아키텍처를 기준으로, 착수 이후 진행된 Host Agent, AI 모델, 웹 대시보드 3개 모듈의 개발 현황과 실험 과정에서 발견된 이슈, 그리고 향후 계획을 정리한다.

본 시스템의 핵심은 Host Agent가 반출 시도를 실시간으로 가로채는 1차 게이트웨이 역할을 수행하고, AI 분석 서버가 문맥을 기반으로 기밀 여부를 판별하는 2차 심층 분석을 담당하는 하이브리드 구조에 있다. 두 모듈은 JSON 기반 REST 통신으로 연동되며, 이 연동 파이프라인의 상세 구조는 2장에서 다룬다.

특히 AI 모델 개발 과정에서 초기 데이터셋 구성 방식에 기인한 도메인 편향 문제를 발견하였으며, 이를 어떻게 진단하고 재설계하고 있는지를 4장에서 상세히 기술한다.

1.1 모듈별 진행 현황 요약

모듈	담당	현재 상태	관련 장
시스템 아키텍처 / AI 연동	공통	3-Tier 구조 및 Agent-AI 서버 통신 스키마 확정	2장
Host Agent	김진우	1단계(클립보드) 완료 / 2·3단계 진행 중	3장
AI 모델	박동화	1차 학습 완료 -> 도메인 편향 발견 -> 재설계 중	4장
웹 대시보드	이상호	FastAPI 로그 수신 API 및 대시보드/로그 상세 화면 1차 구현 완료, 실 Agent 연동·인증은 향후 과제	6장

2. 시스템 아키텍처 및 AI 연동 파이프라인

2.1 전체 시스템 구조

본 시스템은 착수보고서에서 정의한 3계층(3-Tier) 구조를 따른다. 사용자 PC(Host Agent)가 반출 행위를 탐지·제어하고, AI 분석 서버가 문맥을 분석해 기밀 확률을 산출하며, 보안 대시보드가 결과를 시각화·관리한다.

```
[ 사용자 PC (Host Agent) -- 탐지 . 1차 Rule 필터링 . I/O 제어 ]
|
v
[ AI 분석 서버 (KoELECTRA) -- 2차 문맥 분석 . 기밀 확률 산출 ]
|
v
[ 보안 대시보드 -- 로그 시각화 . 상세 분석 . 통계 요약 ]
```

Host Agent는 정규표현식 기반 RuleFilter로 1차 게이트웨이 역할을 수행하여 명백히 무해한 데이터를 조기에 필터링하고, 규칙에 매칭된 의심 데이터에 한해서만 AI 서버로 전달함으로써 전체 트래픽에 대한 상시 딥러닝 추론 비용을 최소화한다. AI 서버는 전달받은 텍스트의 문맥을 분석하여 2차 심층 판별을 수행하고, 최종 판단(allow / review / block)을 Agent에 반환하여 실제 차단·허용이 이루어지도록 한다.

2.2 AI 판별 엔진 연동 파이프라인

Host Agent(core_comm/ApiClient)와 AI 분석 서버는 REST API(JSON) 기반으로 통신한다. 현재는 AI 서버 URL이 미설정된 상태로 개발 중이어서 ApiClient가 mock 모드로 동작하며(severity가 critical/high면 block, medium이면 review), 실제 서버 연동 시에도 동일한 요청/응답 스키마를 그대로 사용할 수 있도록 설계하였다.

Request 예시 (Host Agent -> AI 분석 서버):

```
POST /api/v1/analyze
Content-Type: application/json

{
  "event_id": "evt-20260706-00231",
  "channel": "clipboard",          // clipboard | outlook | http | usb
  "user_id": "device-12345",
  "matched_patterns": ["rrn", "api_key"],
  "snippet": "...전략 문서 관련 매칭 스니펫(+150자, PII 마스킹)...",
  "metadata": {
    "app": "chrome.exe",
    "dest": "external",
    "severity_hint": "high"
  }
}
```

Response 예시 (AI 분석 서버 -> Host Agent):

```
HTTP 200 OK
Content-Type: application/json

{
  "event_id": "evt-20260706-00231",
  "decision": "block",           // allow | review | block
  "confidence_score": 0.93,     // 기밀 확률 (0.0 ~ 1.0)
  "model_version": "koelectra-v0.1-mock",
  "latency_ms": 42
}
```

Agent는 응답의 decision 값에 따라 차단/허용/로그 기록 여부를 즉시 결정하며, confidence_score와 model_version은 대시보드의 상세 로그 화면 및 향후 임계값 튜닝에 활용될 예정이다.

3. Host Agent 개발 현황

Windows 호스트 기반 DLP 에이전트인 「Sentry Host Agent」는 클립보드, 이메일, 웹 업로드, USB·네트워크 공유 등 반출 경로를 모니터링하며, 정규표현식 1차 필터링과 AI 서버 연동(현재 mock 모드) 2차 판단으로 구성된 파이프라인을 갖는다.

3.1 개발 범위 및 진행 상태

구분	내용	상태
1단계	클립보드 제어 (Python)	완료
2단계	네트워크 / 메일 반출 탐지 (Python)	진행 중
3단계	USB · 네트워크 공유 (미니필터 C/C++)	진행 중
공통	이벤트 로깅, AI 페이로드 정제, Windows 서비스	완료

3.2 세부 모듈 구조

프로젝트는 모듈형 단일 레포지토리(sentry-host-agent)로 구성되며, 반출 채널별 모듈(clipboard_ctrl, network_hook, usb_minifilter)과 공통 통신·로깅 모듈(core_comm)로 분리되어 있다. 모든 채널은 동일한 파이프라인을 공유한다.

- 1차 게이트: RuleFilter – regex_patterns.json 기반 정규표현식 매칭 (18종 민감정보 패턴)
- 데이터 정제: PayloadBuilder – 매칭 구간 스니펫 추출, PII 부분 마스킹
- 2차 판단: ApiClient – AI 서버 POST 연동 (현재 mock 모드로 개발 및 테스트 중)
- 조치: block(차단+알림+로그) / review(허용+로그) / allow(통과)

Windows Session 0 격리 제약으로 인해, 서비스 자동 시작 및 크래시 재시작을 담당하는 SentryDLPService(SMTP·HTTP·FileGuard)와 사용자 세션에서 동작하는 SentryUserAgent(클립보드·Outlook·알림)로 구조를 이원화하였다.

3.3 구현 완료 항목

- 클립보드 제어: WH_KEYBOARD_LL 글로벌 훅으로 Ctrl+V 사전 인터셉트, 외부 반출 가능 앱(Slack/Chrome/Discord 등)에 대해서만 검사하고 내부 업무 앱(Excel/Word)은 허용하여 업무 효율성 저하를 최소화
- 공통 모듈: JSONL 기반 로컬 이벤트 저장(10MB 단위 로테이션), 매칭 스니펫 추출 및 severity별 마스킹
- 운영 배포 스크립트: Windows 서비스 등록/제거 자동화(setup_agent.ps1, remove_agent.ps1)

3.4 테스트 현황

pytest 기반 단위 테스트 54건을 작성하여 전건 통과를 확인하였다. 단, 2·3단계(네트워크/메일, USB·네트워크 공유) 관련 테스트는 해당 기능 개발 완료 후 별도 반영할 예정이다.

테스트 파일	대상	결과
test_clipboard.py	TextExtractor, RuleFilter, PasteInspector	19 passed
test_event_logger.py	LocalEventStore, EventLogger	11 passed
test_payload_builder.py	PayloadBuilder, ApiClient mock, 마스킹	24 passed

3.5 주요 기술 결정 및 근거

항목	결정	근거
클립보드 감지	Ctrl+V 인터셉트 + 목적지 정책 기반 검사	내부 앱 업무 효율 유지, 외부 앱만 선택적 검사
AI 분석 호출 시점	정규식 hit 시에만 AI 호출	전체 텍스트 상시 AI 전송에 따른 비용·지연 방지
미니필터 장애 대응	오류 시 기본 허용(Fail-Open)	업무 중단 최소화, 설정으로 Fail-Closed 전환 가능
서비스 구조	2-Process (Session 0 + User)	Windows Session 0 격리 제약 대응

3.6 미완료 항목 및 향후 과제

- 2단계: OutlookHook(메일 반출 검사), SmtProxy(비-Outlook 클라이언트 대응), HttpMonitor(HTTP 업로드 감시), FileInspector(문서 파일 텍스트 추출)
- 3단계: sentry_filter.sys 미니필터 드라이버 빌드 및 서명, 커널-유저모드 통신, USB·SMB 쓰기 감시
- 운영 안정성: 채널 위치독, 설정 hot-reload, 이벤트 배치 전송, 에이전트 heartbeat
- 장기 과제: 실제 Agent 로그 전송 연동, AI 서버 실연동, MSI/NSIS 인스톨러, GPO 배포

4. AI 모델 및 분석 서버 개발 현황

4.1 초기 데이터셋 구성 및 학습

착수보고서 3.2.2절 설계에 따라 KoELECTRA 기반 이진 분류 모델을 1차로 구축하였다. 초기 데이터셋은 '기밀' 클래스에 사이버보안 주제 코퍼스를, '비기밀' 클래스에 일반 뉴스요약 공개 코퍼스(문서요약 프로젝트 데이터셋 등)를 사용하여 구성하였다. 홀드아웃 평가 세트에서는 목표치인 F1 90% 이상에 근접하는 높은 성능을 확인하였다.

4.2 문제 발견: 도메인 편향(Out-of-Distribution 성능 저하)

그러나 학습·평가에 사용되지 않은 새로운 형식의 문서(임의로 작성한 기밀 문서 성격의 텍스트)를 입력하여 정성적으로 점검한 결과, 모델이 기밀 문서를 전혀 탐지하지 못하는 현상을 확인하였다. 홀드아웃 평가 성능과 실제 배포 상황에서의 성능 사이에 뚜렷한 괴리가 발생한 것이다.

4.3 원인 분석

원인을 분석한 결과, 다음과 같은 데이터 구성상의 문제가 확인되었다.

- '기밀' 클래스와 '비기밀' 클래스가 실제로는 '기밀성 여부'가 아니라 '사이버보안 주제 여부'로 구분되어 있었음
- 이에 따라 모델은 문서의 민감도가 아니라 사이버보안 관련 어휘(해킹, 취약점, 악성코드 등)의 존재 여부를 학습한 것으로 판단됨
- 홀드아웃 평가 세트 역시 동일한 두 소스(사이버보안 코퍼스 vs. 뉴스 코퍼스)에서 추출되어, 편향된 모델도 높은 성능으로 측정되는 착시가 발생함
- 실제 기밀 문서는 인사·재무·영업·기술 등 다양한 주제에 걸쳐 존재하므로, '주제'와 '기밀성'을 동일시한 현재 데이터 구성으로는 실전 환경에 일반화되지 않음

4.4 데이터셋 재설계 방향

위 문제를 해결하기 위해 다음과 같은 방향으로 데이터셋을 재설계하고 있다.

- 동일 주제 내 기밀/비기밀 쌍 구성: 재무·영업·기술·인사 등 각 도메인별로 공개 자료(비기밀)와 비공개 톤으로 재구성한 자료(기밀)를 함께 확보하여, 모델이 주제가 아닌 정보의 민감도를 학습하도록 유도
- 합성 데이터 활용: 실제 사내 기밀 문서 확보가 어려운 점을 고려하여, 공개된 공시자료·보도자료 등을 내부 보고서 톤(구체적 수치, 미공개 전망, 내부 용어 반영)으로 재작성하는 방식으로 기밀 문서에 준하는 학습 데이터를 보강
- 평가 방법론 보완: 기존 홀드아웃 평가 외에 학습에 사용되지 않은 도메인·문체의 Out-of-Distribution 테스트셋을 별도로 구성하여, 실제 배포 환경과 유사한 조건에서 재현율(Recall) 및 F1을 검증

4.5 파일럿 검증 결과 및 향후 계획

도메인 편향 문제를 해결하기 위해 재설계된 데이터셋 구축 전략의 타당성을 검증하고자 소규모 파일럿 테스트를 수행하였다.

LLM(Large Language Model)을 활용하여 사이버보안 관련 어휘를 제외하고 재무·영업·인사 등 일반 비즈니스 도메인의 문맥과 비밀성을 반영한 합성 데이터셋(총 40건)을 생성하였다. 이를 기반으로 기존 KoELECTRA 모델을 미세조정(Fine-tuning)한 후, 학습에 활용되지 않은 OOD(Out-of-Distribution) 문장을 입력하여 실시간 추론 점수(Risk Score) 변화를 측정하였다.

검증 결과, 보안 키워드가 포함되지 않은 일반 업무 공지 문장에 대해서는 Risk Score가 5.85점으로 낮게 산출된 반면, 미공개 재무 및 영업 정보가 포함된 기밀 성격의 문장에 대해서는 25.06점으로 약 4.3배 높은 위험도가 측정되었다. 비록 소규모 데이터셋의 한계로 인해 절대적인 점수는 차단 임계값에

미달하였으나, 보안 어휘 부재 시에도 비즈니스 문맥에 따라 위험 점수가 유의미하게 차등 부여됨을 확인하였다.

본 파일럿 검증을 통해 문맥 기반 기밀 탐지 가능성을 확인하였으며, 8월 중 도메인별 합성 데이터 규모 확대, 학습 에포크 및 손실 함수 가중치 조정을 통해 기밀 문장의 Risk Score를 안정적으로 끌어올리고 최적의 차단 임계값(Threshold)을 확정할 예정이다.

4.6 분석 서버 가동 환경

AI 분석 서버는 현재 KoELECTRA 분류 모델을 기반으로 로컬 환경에서 추론 파이프라인을 검증하는 단계이며, Host Agent와의 실연동은 2.2절의 요청/응답 스키마를 기준으로 mock 모드에서 우선 테스트되고 있다. 실 서버 기동 후에는 Swagger(OpenAPI) 문서를 통해 /api/v1/analyze 엔드포인트의 요청 형식, 응답 예시, 오류 코드를 공개할 예정이며, 관련 캡처는 서버 배포 이후 본 보고서 최종본에 반영한다.

5. 테스트 결과 및 통합 테스트 계획

Host Agent 파트의 단위 테스트는 3.4절과 같이 54건 전건 통과(통과율 100%)를 확인하였다. 다만 채널별 세부 응답 지연(ms 단위) 측정은 아직 계측 환경이 구축되지 않아 이번 보고서에는 포함하지 못하였으며, 8월 통합 테스트 단계에서 다음 항목을 함께 측정할 계획이다.

측정 항목	측정 방법	목표치
단위 테스트 통과율	pytest 실행 결과 집계	100% 유지
채널별 로그 수집 지연	이벤트 발생 시각 대비 JSONL 기록 시각 차 (ms)	추후 확정
Agent -> AI 서버 응답 지연	요청 전송~응답 수신 latency_ms 로깅	추후 확정
AI 모델 분류 성능	OOD 테스트셋 기준 F1 / Recall	F1 90% 이상, Recall 우선

통합 테스트 계획: Host Agent(1차 필터링) -> AI 분석 서버(2차 판별) -> 대시보드(결과 시각화)로 이어지는 전체 파이프라인에 대해, 실제 반출 시나리오(웹메일 첨부, 클립보드 복사, USB 복사)를 재현하여 종단 간(End-to-End) 탐지 여부와 지연 시간을 검증할 예정이다.

6. 웹 대시보드 개발 현황

웹 대시보드는 Host Agent가 수집한 탐지 이벤트와 AI 민감도 분석 결과를 보안 담당자가 한 화면에서 확인할 수 있도록 구성한 관리자 화면이다. 현재 구현 범위는 FastAPI 기반 로그 수신/조회 API, SQLite 기반 프로토타입 저장소, 대시보드 요약 화면, 로그 상세 분석 화면이다. 실제 Agent 및 AI 서버가 완전히 실연동되기 전에도 동일한 JSON 형식의 샘플 로그를 전송하여 API 수신, DB 저장, 화면 반영 흐름을 검증할 수 있도록 구현하였다.

6.1 개발 범위 및 구현 상태

기능	상태	구현 내용
Agent 로그 수신 API	완료	POST /api/v1/logs로 Host Agent 형식의 탐지 로그를 수신하고 DB에 저장
로그 조회/필터 API	완료	조치 결과, 유출 채널, 부서, 사용자, 기간, 키워드 기준의 로그 검색 및 목록 조회 지원
대시보드 요약 API	완료	전체 이벤트 수, 차단/경고/허용 건수, 평균 AI 점수, 채널 분포, 부서별 위험도, 고위험 이벤트 집계
관리자 대시보드 화면	완료	/dashboard에서 KPI 카드, 고위험 이벤트, 채널 분포, 부서별 위험도, 최근 로그를 시각화
로그 상세 분석 화면	완료	/logs에서 10개 단위 페이지네이션, 스크롤 가능한 로그 목록, 선택 로그의 탐지 근거 패널 제공
인증/권한 및 운영 배포	예정	로그인, 역할 기반 접근 제어, HTTPS, 운영 DB 전환은 통합 단계에서 보완 예정

6.2 백엔드 및 REST API 구현

백엔드는 backend/main.py의 FastAPI 애플리케이션으로 구성하였다. 프로토타입 단계에서는 backend/dlp_dashboard.db SQLite 파일을 사용하며, 탐지 로그 테이블과 정책 테이블을 초기화한 뒤 REST API를 통해 프론트엔드에 필요한 데이터를 제공한다.

- POST /api/v1/logs: Host Agent 또는 샘플 전송 스크립트가 보낸 탐지 로그를 수신하고 저장한다.
- GET /api/v1/logs: 대시보드와 로그 페이지에서 사용할 로그 목록을 조회하며, 조치 결과/채널/부서/사용자/기간/키워드 필터를 지원한다.
- GET /api/v1/logs/{log_id}: 특정 로그의 상세 정보와 AI 분석 근거를 조회한다.
- GET /api/v1/dashboard/summary: KPI, 채널 분포, 부서별 위험도, 고위험 이벤트, 최근 추세 데이터를 집계한다.
- GET /api/v1/logs/filter-options: 화면 필터 드롭다운에 사용할 부서, 사용자, 조치 결과, 채널 목록을 제공한다.

6.3 프론트엔드 화면 구현

프론트엔드는 밝은 사이드바형 관리자 콘솔 형태로 구성하였으며, 대시보드 화면과 로그 상세 화면을 분리하였다. /dashboard는 전체 보안 현황을 빠르게 파악하는 요약 화면이고, /logs는 개별 탐지 로그를 검토하는 분석 화면이다.

- 대시보드 화면: 전체 로그 수, 차단 건수, 경고 건수, 허용 건수, 평균 AI 점수를 카드 형태로 제공하고, 고위험 이벤트는 최신순으로 왼쪽부터 배치하여 가로 스크롤로 확인할 수 있게 하였다.

- 시각화 영역: 최근 위험도 추세, 유출 채널 분포, 부서별 위험도, 최근 로그를 함께 배치하여 반출 경로와 위험 부서를 빠르게 파악할 수 있도록 하였다.
- 로그 상세 화면: 로그 목록은 한 페이지에 10개씩 보여주고, 항목 클릭 시 선택한 로그의 사용자, 부서, 파일명, 유출 채널, AI 점수, 탐지 근거를 상세 패널에 표시한다.
- 화면 연동: 대시보드의 고위험 이벤트 또는 최근 로그를 클릭하면 /logs 화면으로 이동하고, 해당 로그가 목록에서 강조되며 상세 정보가 바로 표시되도록 구현하였다.

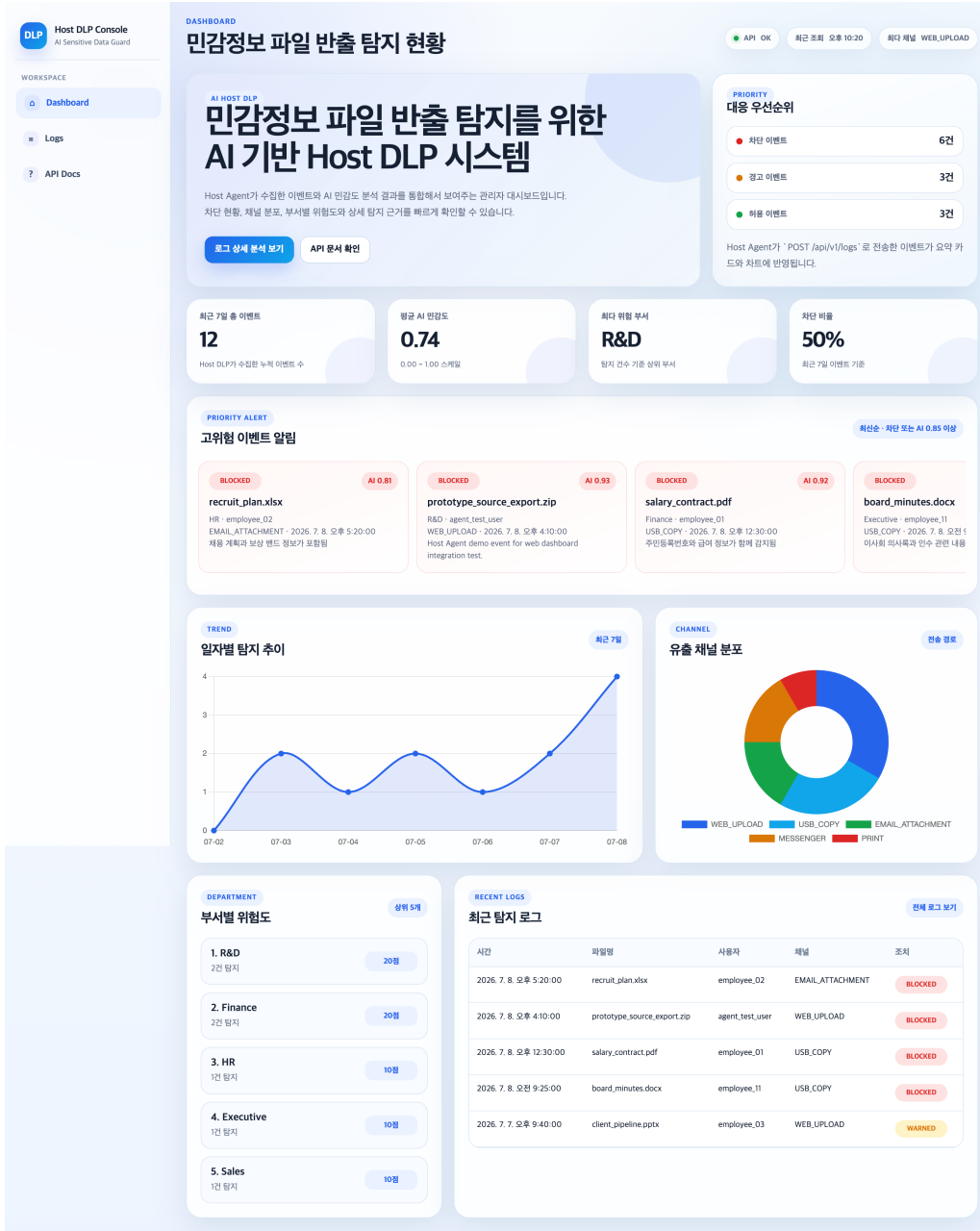


Figure 1: 샘플 탐지 로그 기반 관리자 대시보드 화면

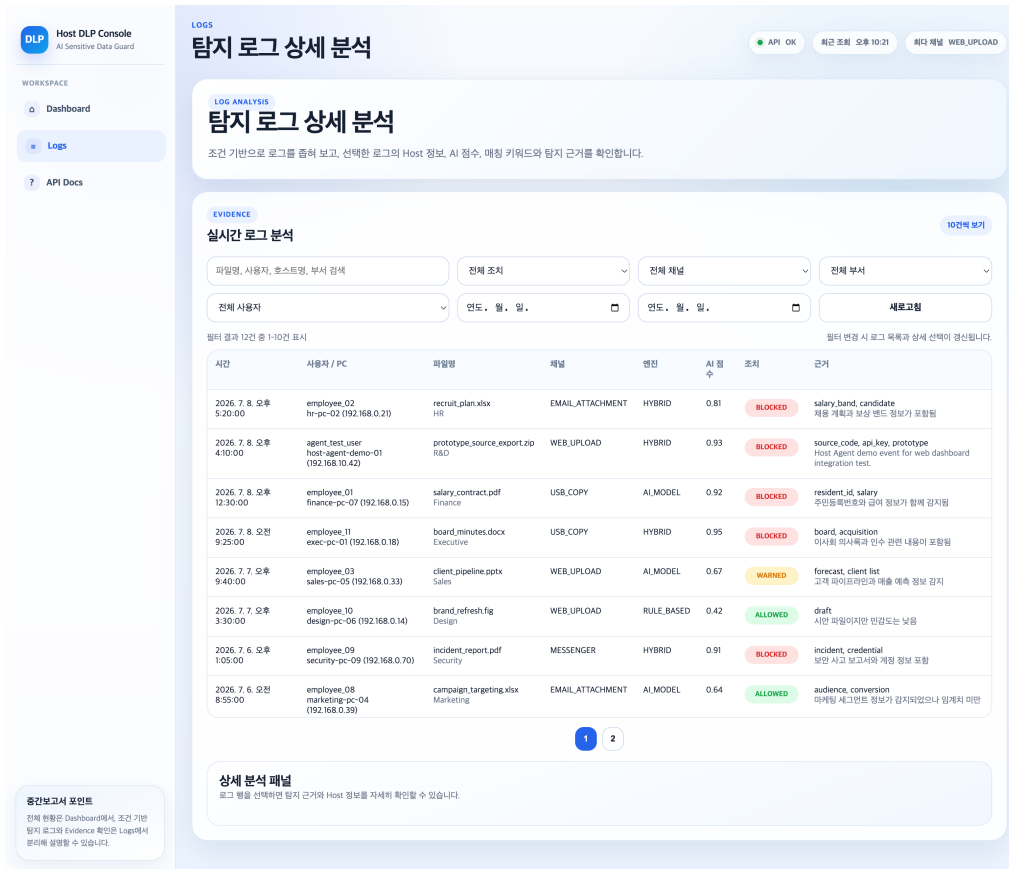


Figure 2: 탐지 로그 목록

6.4 샘플 데이터 및 검증 현황

현재 프로토타입 DB에는 2026년 7월 3일부터 2026년 7월 8일까지의 샘플 탐지 로그 12건을 구성하였다. 샘플 기준 집계 결과는 전체 12건 중 차단 6건, 경고 3건, 허용 3건이며 평균 AI 점수는 0.74이다. 이를 통해 대시보드 KPI, 채널 분포, 부서별 위험도, 고위험 이벤트 노출, 로그 상세 조회가 정상적으로 연결되는 것을 확인하였다.

또한 scripts/send_sample_log.py를 작성하여 실제 Host Agent가 완성되기 전에도 POST /api/v1/logs API에 JSON 로그를 전송할 수 있도록 하였다. 이 스크립트는 팀원과 전송 스키마를 조율하거나 Swagger/OpenAPI 문서로 API 형식을 확인할 때 테스트 도구로 활용할 수 있다.

6.5 미완료 항목 및 향후 과제

현재 대시보드는 중간보고서 단계의 기능 검증용 프로토타입이므로, 운영 환경 적용을 위해서는 다음 보완이 필요하다.

- 실제 Host Agent와 연동하여 이벤트 발생 시점, 파일 경로, 사용자 식별자, AI 점수 필드의 최종 전송 스키마를 확정한다.
- AI 서버 실연동 이후 ai_score 기준 고위험 판단 임계값과 차단/경고/허용 정책을 튜닝한다.
- 로그인, 역할 기반 접근 제어, API 인증 토큰, HTTPS 적용 등 관리자 대시보드 접근 보안 요소를 추가한다.

- SQLite 프로토타입 DB를 운영용 DB로 전환하고, 장기 로그 저장/검색 성능과 감사 로그 보존 정책을 설계한다.

7. 구성원별 진척도

팀원	역할
박동화	- KoELECTRA 기반 분류 모델 1차 학습 완료 - 홀드아웃 대비 OOD 성능 저하 원인 분석 및 데이터셋 재설계 진행 중 - 도메인x기밀성 매트릭스 기반 파일럿 데이터 구성 중
김진우	- 클립보드 제어 모듈(1단계) 개발 및 단위테스트 완료 - 네트워크/메일 반출 탐지(2단계) 개발 진행 중 - USB·미니필터(3단계) 설계 및 초기 구현 진행 중
이상호	- FastAPI 기반 Host Agent 로그 수신/조회 REST API 구현 - 대시보드 요약 화면과 로그 상세 분석 화면 구현 - 샘플 로그 데이터 구성 및 API 전송 스크립트 작성

8. 향후 추진 계획

착수보고서 상 5월~9월 일정을 기준으로, 현재 시점(7월 중순) 이후의 세부 계획은 다음과 같다.

시기	AI 모델	Host Agent	웹 대시보드
7월	도메인x기밀성 데이터셋 재설계 및 파일럿 검증	2단계(메일/네트워크) 개발 완료	대시보드/로그 화면 1차 구현, 샘플 데이터 검증
8월	재설계 데이터 학습, OOD 평가 및 임계값 튜닝	3단계(USB·미니필터) 개발 및 통합 테스트	실제 Agent 로그 연동, 상세 화면 보완
9월	AI 서버 실연동 및 성능 최종 검증	전 채널 통합 및 안정성 테스트	인증/권한, 배포 설정, 시연 데이터 정리